

ACTIVITY PACK

Activity 3: Discussion Questions

Activity 3 - Selecting a Security Framework for GenAI and Agents

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	2.1 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Discussion Questions

Activity 3 - Discussion Questions

Selecting a Security Framework for GenAI and Agents

Work through all five questions in your group. Nominate one person to present your framework recommendation and your measurement plan in the debrief. You have 60 minutes.

The audit committee wants one framework name. You are going to tell them that is the wrong question. Make sure you can also tell them what the right one is.

Q1 - Establish what each framework is actually for (A3)

Before selecting anything, classify the six candidates.

- For each of the six, state in one line **what kind of artefact it is** - a threat taxonomy, a lifecycle process, an adversary knowledge base, a governance framework, or a statutory obligation - and what question it answers that the others do not.

- Identify which **one** of the six Straits Meridian has no choice about, and explain why that changes how it enters the plan.

- The systems integrator's attestation says Kirana "has been assessed against the OWASP Top 10 for LLM Applications 2026 with no critical findings." State **three** specific things that attestation does not tell the board, given what Kirana actually is.

Q2 - Map the frameworks onto the two components (A3)

Components A and B differ in kind, not merely in size.

- Build a table mapping each framework to Component A, Component B, or both - and where a framework applies to both, say whether it applies *differently*.

- Name the specific **ASI 2026 entries** that Component B raises and the LLM 2026 entries do not fully cover, using the evidence in the scenario: unattended overnight operation, delegated credentials to four external systems, a 14-month persistent memory store, and escalation only after three failures.

- The two components share a foundation model, a vector database, a logging pipeline and - critically - **one service account**, svc-kirana-prod. Explain what that shared identity does to your risk assessment, and which framework's language you would use to raise it with the board.

Q3 - Answer the four pressures (A3)

The board, the integrator, the insurer and the regulator are asking four different questions.

- For each of the four pressures in the scenario, state which framework (or combination) answers it, and what artefact you would actually produce - a document, a register, a test report, a control.

- The regulator's question is about **human accountability for autonomous decision-making**. Answer it concretely for Component B: where do approval checkpoints go, which actions are irreversible, and what would you audit? The current design escalates only after three failed attempts on the same claim - assess whether that is an approval checkpoint at all.

- The insurer wants "a process, not a point-in-time test." Explain which framework supplies that, and map the four Kirana activities you would place under **Govern, Map, Measure and Manage**.

Q4 - Interpret the red-team results (A5)

Work from the artefact tables. Show your reasoning, not just conclusions.

- Attack success rate falls from 34.2% (V1) to 4.1% (V4), but the ****false-positive rate on benign prompts rises from 1.2% to 22.3%****. At 40,000 conversations a month, convert both numbers into consequences the board understands. Recommend a variant and defend the trade-off you are accepting.
- V3's aggregate 11.4% conceals a wide spread by attack family. Identify the ****two families where V3 performs worst****, explain why prompt-level defences are weak against precisely those two, and state what class of control would actually move them.
- Refusal rate and attack success rate do not sum to 100% in any variant. Explain what is happening in the gap, and why **refusal rate alone is a misleading headline metric** for a board.
- Component B's numbers are materially worse than Component A's on every comparable measure, despite an equivalent configuration. Give the architectural reason.

Q5 - Define the measurement plan and the go-live decision (A5, A3)

The CISO wants a combination, a rationale, and a phase-two deferral list.

- Define the **metrics and the thresholds** Kirana must meet before 1 November - for each metric state the measure, the threshold, and how it is tested. Cover both components, and include at least one metric that is **not** an attack metric.
- State how often the tests are re-run and what triggers an unscheduled re-run. A model version change? A corpus update? A new tool? Justify your triggers.
- Component B's escalation controls drop auto-processing from 94.1% to 71.6%, at 7 minutes of finance officer time per escalation and 3,100 claims a night. Calculate the operational cost, compare it to the 6.5 FTE the programme was meant to save, and state whether the business case survives.
- Give your **go-live recommendation** for 1 November: both components, one, or neither. Name what you defer to phase two and what evidence would release it.